

Lab 1.1 — FortiGate Administration

Administrative Accounts, Profiles, and Password Controls

1. Administrator Accounts

A FortiGate is rarely managed by one person. Multiple administrators need access, and giving each of them full rights is both unnecessary and difficult to audit — when every account can do everything, the change log cannot distinguish an intended action from a mistake.

FortiOS separates the account from its permissions. An administrator account holds the identity and the login controls; an admin profile holds the permissions. Accounts reference a profile, so permissions are defined once and applied consistently.

Profile Name	Comments	Ref
prof_admin		0
super_admin		2

Figure 1 — The Admin Profiles list, showing the two built-in profiles and their reference counts

The reference count in the list shows how many accounts use each profile. A profile in use cannot be deleted, which prevents an administrator from being orphaned by a profile removal.

2. Built-in Profiles

FortiOS ships with two profiles. Both grant full access, but they differ in one important respect.

Name	Comments	Access Permissions
super_admin	0/255	Access Control: Permissions: Set All Security Fabric: [None] [Read] [Read/Write] FortiView: [None] [Read] [Read/Write] User & Device: [None] [Read] [Read/Write] Firewall: [None] [Read] [Read/Write] [Custom] Log & Report: [None] [Read] [Read/Write] [Custom] Network: [None] [Read] [Read/Write] [Custom] System: [None] [Read] [Read/Write] [Custom] Security Profile: [None] [Read] [Read/Write] [Custom] VPN: [None] [Read] [Read/Write]
prof_admin	0/255	Access Control: Permissions: Set All Security Fabric: [None] [Read] [Read/Write] FortiView: [None] [Read] [Read/Write] User & Device: [None] [Read] [Read/Write] Firewall: [None] [Read] [Read/Write] [Custom] Log & Report: [None] [Read] [Read/Write] [Custom] Network: [None] [Read] [Read/Write] [Custom] System: [None] [Read] [Read/Write] [Custom] Security Profile: [None] [Read] [Read/Write] [Custom]

Figure 2 — *super_admin* (left) is read-only; *prof_admin* (right) can be edited

Profile	Permissions	Editable
super_admin	Read/Write across every access control area, with no exceptions	No — locked by the system
prof_admin	Read/Write across every area, with Custom options available per area	Yes

► 2.1 Why *super_admin* Cannot Be Edited

The *super_admin* profile cannot be modified or deleted. This is deliberate: it guarantees that at least one profile with full access always exists, so an administrator cannot lock the organisation out of its own firewall by editing permissions incorrectly. It is the recovery path of last resort at the permission layer.

In practice: *prof_admin* grants the same access but is editable, which makes it the profile to modify if a broad administrative role needs narrowing. Building a purpose-specific custom profile is usually better than editing a built-in one — a custom profile carries its intent in its name.

3. Building a Custom Profile

A new profile starts with every access control area set to None. Permissions are granted deliberately rather than removed from a full set, which is the correct default for least privilege.

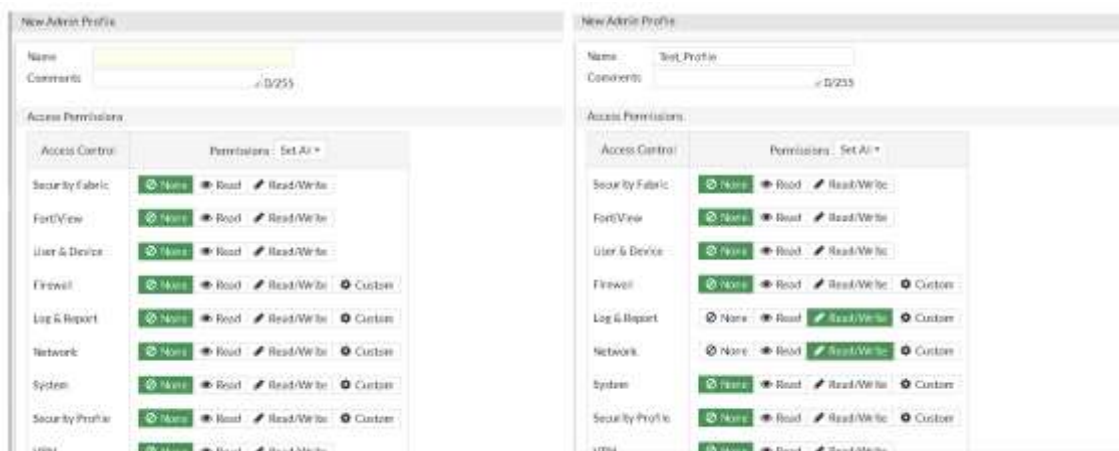


Figure 3 — A new profile defaults to None (left); Test_Profile grants Network and Log & Report only (right)

Each access control area accepts one of three settings, and several accept a fourth.

Setting	Effect
None	The area is hidden from the GUI entirely. The administrator cannot see it, not merely edit it
Read	The area is visible but cannot be changed. Suited to auditors and to help desk staff who need to check state without altering it
Read/Write	Full access to that area
Custom	Available on Firewall, Log & Report, Network, System, and Security Profile. Permits per-sub-area granularity — for example, read access to firewall policies but write access to address objects

► 3.1 The Test Profile

For this lab, `Test_Profile` was created with Read/Write on Network and Log & Report and None everywhere else. This models a realistic role: a network operations engineer who needs to manage interfaces and routing and review logs, but should not be able to alter firewall policy, VPN configuration, or the appliance's own settings.

4. Creating an Administrator

The screenshot shows the 'New Administrator' configuration interface. The 'Username' field is 'Test'. The 'Type' dropdown is set to 'Local User'. The 'Password' and 'Confirm Password' fields are masked with dots. The 'Comments' field is empty. The 'Administrator profile' dropdown is set to 'Test_Profile'. Below the main form, there are two sections: 'Two-factor Authentication' which is disabled, and 'Restrict login to trusted hosts' which is enabled. Under the 'Restrict login to trusted hosts' section, there is a table with one entry: 'Trusted Host 1' with the value '172.16.19.44/16'.

Figure 4 — An administrator account bound to Test_Profile, with trusted host restriction

► 4.1 Account Type

Type	Behaviour
Local User	Credentials stored on the FortiGate itself. Simple, but each account must be managed per device
Match a user on a remote server group	One named user authenticated against LDAP or RADIUS
Match all users in a remote server group	Any member of a directory group receives this profile. The scalable option — administrator turnover is handled in the directory rather than on every appliance
PKI group	Certificate-based authentication, with no password to steal or guess

► 4.2 Trusted Hosts

The account created here restricts login to 172.16.19.44/16. With trusted hosts enabled, the FortiGate refuses the login attempt regardless of whether the credentials are correct — an attacker with a valid stolen password still cannot authenticate from outside the permitted range.

Locking yourself out is easy. If a trusted host range is set incorrectly on the only administrative account, GUI and SSH access are gone and recovery requires console access. Verify the range from a second session before closing the one that configured it.

5. Verifying the Profile

A permission model is only as good as its verification. Logging in as the restricted account is the only way to confirm the profile does what was intended.



Figure 5 — The GUI as seen by the test account — only Dashboard, Network, and Log & Report are present

The menu tree confirms the profile is applied correctly. Policy & Objects, Security Profiles, VPN, User & Authentication, System, and Security Fabric are not merely disabled but absent, because areas set to None are hidden rather than greyed out.

Design property: hiding an area removes the temptation to attempt access and removes the information disclosure that a greyed-out menu provides — a restricted administrator learns nothing about what exists beyond their scope.

6. Password Policy

A password policy enforces complexity requirements centrally rather than relying on each administrator to choose well.

The screenshot shows the 'Password Policy' configuration page in the FortiGate GUI. The 'Admin' tab is selected. The configuration includes: 'Password scope' set to 'Admin'; 'Minimum length' set to 14; 'Minimum number of new characters' set to 0; 'Character requirements' enabled with a green toggle; 'Upper case' set to 2; 'Lower case' set to 0; 'Numbers (0-9)' set to 4; 'Special' set to 2; 'Allow password reuse' disabled with a grey toggle; and 'Password expiration' set to 90 days with a green toggle.

Figure 6 — Password policy configured for administrator accounts

Setting	Value used	Effect
Password scope	Admin	Applies to administrator accounts. Can also cover IPsec pre-shared keys, both, or neither
Minimum length	14	Length contributes more to brute-force resistance than character complexity does
Minimum new characters	0	How many characters must differ when a password is changed
Character requirements	2 upper, 4 numeric, 2 special	Minimum count per character class
Allow password reuse	Disabled	Prevents setting a previously used password again
Password expiration	90 days	Forces a change after the interval

► 6.1 On Forced Expiry

NIST SP 800-63B no longer recommends forced periodic expiry, having found that it drives predictable transformations that weaken passwords rather than strengthening them. Current guidance favours greater length, screening against known-breached passwords, and forced change only on evidence of compromise.

Where a compliance regime mandates expiry, the setting is here. Where there is discretion, length and multi-factor authentication return more.

7. Password Recovery and the Maintainer Account

If the administrator password is lost, FortiOS provides a recovery path through a special built-in account named maintainer.

► 7.1 How It Works

Property	Detail
Username	<code>maintainer</code>
Password	<code>bcpb</code> followed immediately by the appliance serial number, with no separator
Access method	Console connection only. The account cannot be used over SSH, Telnet, or the GUI
Availability window	A short period immediately after boot — approximately 60 seconds on most models. It is unavailable at any other time
Prerequisite	The device must be power-cycled, so physical access is required

► 7.2 The Recovery Sequence

- Power the appliance off.
- Connect a console cable and open a terminal session.
- Power the appliance on and watch the boot output.
- Log in as `maintainer` with `bcpb<serial-number>` within the window. The prompt appears only briefly, so the credentials must be ready to paste.
- Reset the target account password from the CLI.

```
config system admin
  edit <username>
    set password <new-password>
  next
end
```

The same commands work from any account holding sufficient privileges, so the maintainer route is needed only when no usable administrative credential remains.

► 7.3 Why the Constraints Exist — and Why You May Want to Remove It

The maintainer account is deliberately bounded: console-only, boot-window-only, and dependent on the serial number, which is printed on the chassis. Together these mean the account is usable only by someone with physical possession of the appliance and the ability to power-cycle it.

That is the point, and also the risk. Anyone with physical access to the device can take full administrative control of it, regardless of how strong the configured passwords are. In a locked data centre this is an acceptable trade. In a branch office wiring closet, or an unattended cabinet on a plant floor, it may not be.

The account can be disabled with `set admin-maintainer disable` under `config system global`. Doing so removes the recovery path permanently: if administrative credentials are then lost, the only remaining option is a factory reset via the boot menu, which erases the configuration. Disable it only where physical security is genuinely uncertain and a current configuration backup is guaranteed.

8. Lockout and Retry Limits

FortiOS limits how many consecutive failed login attempts an account may accumulate before it is temporarily locked. The defaults are three failed attempts followed by a 60-second lockout.

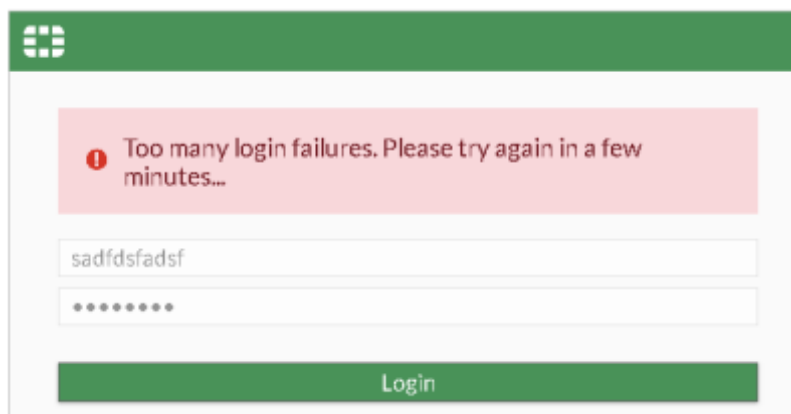


Figure 7 — The lockout message returned after exceeding the retry threshold

The lockout applies to the account, and the message returned to the user names no reason beyond the failure count — it does not disclose whether the username exists or whether the password was close.

► 8.1 Adjusting the Thresholds

```
config system global
  set admin-lockout-threshold <failed-attempts>
  set admin-lockout-duration <seconds>
end
```

Parameter	Default	Purpose
admin-lockout-threshold	3	Consecutive failed attempts permitted before logout
admin-lockout-duration	60	Length of the lockout in seconds

9. Summary

Component	Details
Account model	Accounts hold identity and login controls; profiles hold permissions
Built-in profiles	<code>super_admin</code> is locked; <code>prof_admin</code> is editable
Custom profile	Test_Profile — Read/Write on Network and Log & Report, None elsewhere
Verification	Restricted account sees only three menus; hidden areas are absent, not greyed out
Trusted hosts	Login refused from outside the range even with valid credentials
Password policy	14 characters, character class minimums, reuse disabled, 90-day expiry
Recovery	<code>maintainer</code> — console only, boot window only, requires physical access
Lockout	3 failed attempts, 60-second lockout, both tunable from the CLI